

category: networking-protocol

tags: [reverse-proxy, http, zkteco, push-protocol, source-ip, vendor-software, wireshark]

severity: medium

created: 2026-07-29

updated: 2026-07-29

project-origin: App-Access-V2 (ZkPushMonitor — giám sát giao thức ZKTeco PUSH)

HTTP reverse-proxy trong suốt (byte-for-byte) vẫn có thể làm hỏng tính năng "gửi lệnh tức thời" của phần mềm hãng vì nó định tuyến lệnh theo IP nguồn, không chỉ theo định danh trong body

Tình huống gặp phải

Xây dựng `ZkPushMonitor` — tool proxy HTTP trong suốt giữa thiết bị ZKTeco (giao thức PUSH) và phần mềm hãng (ZKBioAccess), để ghi lại chuỗi lệnh khởi tạo. Proxy forward **nguyên byte** 2 chiều, đã verify bằng sha1 khớp tuyệt đối giữa request/response gốc và bản forward.

Sau khi dùng tool để giám sát thật với thiết bị + phần mềm hãng thật, user thử tính năng "Remote Opening"/"Synchronize Time" từ giao diện quản trị phần mềm hãng — các lệnh này **không có tác dụng** khi đi qua tool, dù mọi route khác (`registry`, `cdata`, `push`, `ping`, `getrequest`) đều hoạt động và ghi lại đúng.

Triệu chứng / Lỗi

- Phần mềm hãng báo UI "hoàn thành"/"Submit" ngay lập tức khi bấm nút lệnh.
- Bảng Command Log của phần mềm hãng sau đó tự điền `Return Time + Returned Value = -1110` cho MỌI lần thử — độ trễ giữa `Submit Time` và `Return Time` **luôn đúng ~30 giây tuyệt đối** ở mọi lần thử (30s, 30s, 31s, 30s) — dù thiết bị vẫn đang poll `getrequest` đều đặn mỗi ~2 giây.
- Tool (JSONL, quét toàn bộ session) xác nhận **0 lệnh** (`Commands` rỗng) từng xuất hiện trong response `getrequest` suốt phiên.
- Wireshark lọc theo IP thiết bị xác nhận **không có traffic** nào ngoài port monitor của tool (loại trừ khả năng phần mềm hãng dùng kênh riêng/port khác để gửi lệnh).
- Khi đổi thiết bị trở **thăng** (bỏ qua tool, không proxy) → lệnh chạy **bình thường**.

Nguyên nhân gốc rễ (Root Cause)

Độ trễ ~30 giây **cố định tuyệt đối** ở mọi lần thử — bất kể chu kỳ poll thật của thiết bị (~2s) — là dấu hiệu của **timeout nội bộ cố định trong phần mềm hãng** (chờ xác nhận không thấy → tự gán mã lỗi), KHÔNG phải round-trip time thật với thiết bị.

Kết hợp với proxy forward nguyên byte (đã verify không có gì bị mất/sai ở tầng application), nguyên nhân hợp lý nhất: **phần mềm hãng định tuyến lệnh nội bộ (khớp lệnh đang xếp hàng với đúng phiên/kết**

nối polling) theo địa chỉ IP nguồn của kết nối TCP, không chỉ theo Serial Number trong query string. Khi đi qua reverse-proxy, IP nguồn mà phần mềm hãng nhìn thấy đổi từ IP LAN thật của thiết bị thành `127.0.0.1` (địa chỉ tool gọi tới nó) — phần mềm hãng vẫn nhận diện đúng thiết bị qua SN cho luồng dữ liệu đẩy lên (event/log/register — vì các luồng này không cần "gửi lệnh xuống đúng phiên"), nhưng cơ chế "queue lệnh + khớp vào đúng kết nối polling đang mở" lại phụ thuộc IP, nên bị lệch, lệnh không bao giờ được gắn vào đúng phiên `getrequest` đang chạy.

Giải pháp

Không sửa được ở tầng tool (đây là hành vi bên trong phần mềm hãng, closed-source) — chỉ có thể:

1. Xác nhận qua đo lường: so khớp `Return Time - Submit Time` giữa nhiều lần thử — nếu **luôn cố định** (không dao động theo chu kỳ poll thật) → gần như chắc chắn là timeout nội bộ, không phải phản hồi thiết bị thật.
2. Đối chiếu song song: quét toàn bộ JSONL của tool xem có `Commands` nào khớp thời điểm không; bắt Wireshark xem có traffic ngoài port proxy không (loại trừ kênh ẩn khác).
3. Test đối chứng dứt điểm: tạm bỏ proxy (trở thẳng thiết bị → phần mềm hãng) và thử lại đúng thao tác — nếu thành công thì xác nhận 100% nguyên nhân là do proxy.
4. Chấp nhận giới hạn: dùng proxy để **giám sát/ghi log** (mục đích chính, không bị ảnh hưởng), tạm tắt proxy khi cần **test tính năng gửi lệnh tức thời** từ phần mềm hãng.

Áp dụng lại (How to reuse)

- Khi build 1 reverse-proxy giám sát giao thức thiết bị IoT/access-control (ZKTeco, Hikvision, Dahua...) — LUÔN cảnh báo trước rằng tính năng **điều khiển/lệnh tức thời khởi xướng từ server** có rủi ro cao hơn nhiều so với luồng **thiết bị đẩy dữ liệu lên**, vì nhiều phần mềm quản lý dùng IP nguồn làm 1 phần khoá định tuyến nội bộ (session affinity), không chỉ dùng định danh trong body.
- Thấy `Return Time - Submit Time` **cố định tuyệt đối** qua nhiều lần thử khác nhau về thời điểm bấm → nghi ngay là timeout nội bộ của hệ thống đang test, không phải độ trễ mạng/thiết bị thật.
- Trước khi kết luận "tool có bug", luôn có 1 bước đối chứng: tắt tool, test trực tiếp — nếu vẫn lỗi thì lỗi nằm ở phần mềm hãng/thiết bị, không phải ở proxy.

Chú ý / Cạm bẫy (Gotchas)

- ⚠ Forward "nguyên byte, verify bằng sha1 khớp tuyệt đối" **KHÔNG đảm bảo** tính năng phía sau hoạt động y hệt — vì hành vi phần mềm hãng có thể phụ thuộc thông tin NGOÀI nội dung HTTP (địa chỉ IP/port TCP của kết nối), thứ mà bản chất reverse-proxy luôn làm thay đổi (client thấy IP nguồn là proxy, không phải máy gốc).
- ⚠ Đừng vội kết luận "lệnh gửi thành công" chỉ vì UI phần mềm hãng báo xanh/"hoàn thành" ngay khi bấm nút — đó thường chỉ là xác nhận **đã ghi vào hàng đợi**, không phải xác nhận **thiết bị đã nhận và thực thi**. Phải nhìn cột `Return Time/Returned Value` (hoặc tương đương) để biết kết quả thật.

Tham chiếu

- Project liên quan: App-Access-V2 — `iAccessDesktopv2.Avalonia/iAccess.Tools.ZkPushMonitor/`
- Tài liệu: `docs/manuals/MANUAL-zkpush-monitor.md` §7 (Giới hạn đã biết)